

Report di Analisi Sandbox

Verifica di sicurezza su link di email marketing
(ConvertKit → Instagram / Facebook)

VERDETTO: NESSUNA MINACCIA CONFERMATA

Autore / Team:	Team Akatsuki
Tipo di documento:	Report tecnico di analisi malware / phishing
Strumento di analisi:	ANY.RUN Interactive Sandbox (Windows 10 64bit)
Data esecuzione sandbox:	25.08.2024, ore 22:44 — durata 62 secondi
Oggetto analizzato:	Link click-tracker ConvertKit
Destinatario:	Cliente / Management (non tecnico)

Indice

1. Executive Summary	3
2. Oggetto dell'analisi	3
3. Metodologia di analisi	4
4. Evidenze raccolte	4
5. Analisi della URL e della catena di redirect	5
6. Analisi del traffico di rete e DNS	6
7. Analisi dei processi	7
8. Elemento di attenzione: processo RUXIMICS.exe	7
9. Tabella di classificazione e remediation	8
10. Conclusioni finali	9

1. Executive Summary

Il Team Akatsuki ha condotto un'analisi tecnica approfondita su un link presente in una email di marketing, al fine di verificarne la sicurezza prima di un'eventuale interazione da parte degli utenti aziendali. L'analisi è stata condotta in un ambiente isolato e controllato (sandbox), che permette di osservare il comportamento reale di un link o di un file senza esporre l'infrastruttura del cliente ad alcun rischio.

Risultato principale: il link analizzato è risultato **legittimo**. Si tratta di un normale "click-tracker" generato dalla piattaforma di email marketing **ConvertKit (Kit)**, che reindirizza l'utente verso le pagine di accesso **autentiche** di Facebook e Instagram. Non sono stati rilevati siti contraffatti, furto di credenziali, download di file dannosi o comunicazioni con server sospetti.

Durante l'approfondimento, è stato individuato un secondo elemento, **indipendente** dal link analizzato: un processo software (`RUXIMICS.exe`) già attivo sulla macchina di test prima dell'inizio dell'analisi. L'approfondimento (capitolo 8) ha identificato questo processo come componente legittimo di Windows Update ("Reusable UX Interaction Manager"); il punto è stato chiuso come presumibile falso positivo, senza azioni di contenimento, pur non essendo stato possibile ottenere una conferma crittografica puntuale del campione specifico.

2. Oggetto dell'analisi

È stato sottoposto ad analisi il seguente URL, ricevuto tramite una email di marketing:

```
https://click.convertkit-mail2.com/wvugovqrrwagh50ndddc7hnxdlxxu8/48hvhehr87opx8ux/d3d3Lmluc3RhZ3JhbS5jb20vYXVzc211bnVyc2VyZWNYdW10ZXJz
```

Questo tipo di link è comunemente utilizzato dalle piattaforme di email marketing per misurare quante persone cliccano sui contenuti di una newsletter, prima di reindirizzarle alla pagina di destinazione reale. È lo stesso meccanismo utilizzato, ad esempio, dai principali provider di posta e marketing automation (Mailchimp, HubSpot, ConvertKit, ecc.).

3. Metodologia di analisi

Per garantire un verdetto affidabile, il Team Akatsuki non si è basato su un singolo indicatore, ma ha incrociato **cinque livelli di verifica indipendenti**, in modo che un'eventuale minaccia nascosta non potesse sfuggire a tutti i controlli contemporaneamente:

- **Verdetto comportamentale della sandbox** — motore automatico di detection ANY.RUN
- **Analisi statica dell'URL** — decodifica manuale della struttura del link
- **Traffico di rete (TCP/UDP)** — verifica di ogni connessione stabilita e relativo processo generante
- **Risoluzioni DNS** — verifica che ogni dominio contattato risolva verso l'infrastruttura IP corretta
- **Command line e albero dei processi** — verifica che nessun processo anomalo o script nascosto sia stato eseguito

4. Evidenze raccolte

La sandbox ANY.RUN ha eseguito il link in un ambiente Windows 10 isolato, restituendo un verdetto automatico di **"No threats detected"** e **0 Network Threats** rilevate, come mostrato nello screenshot seguente.

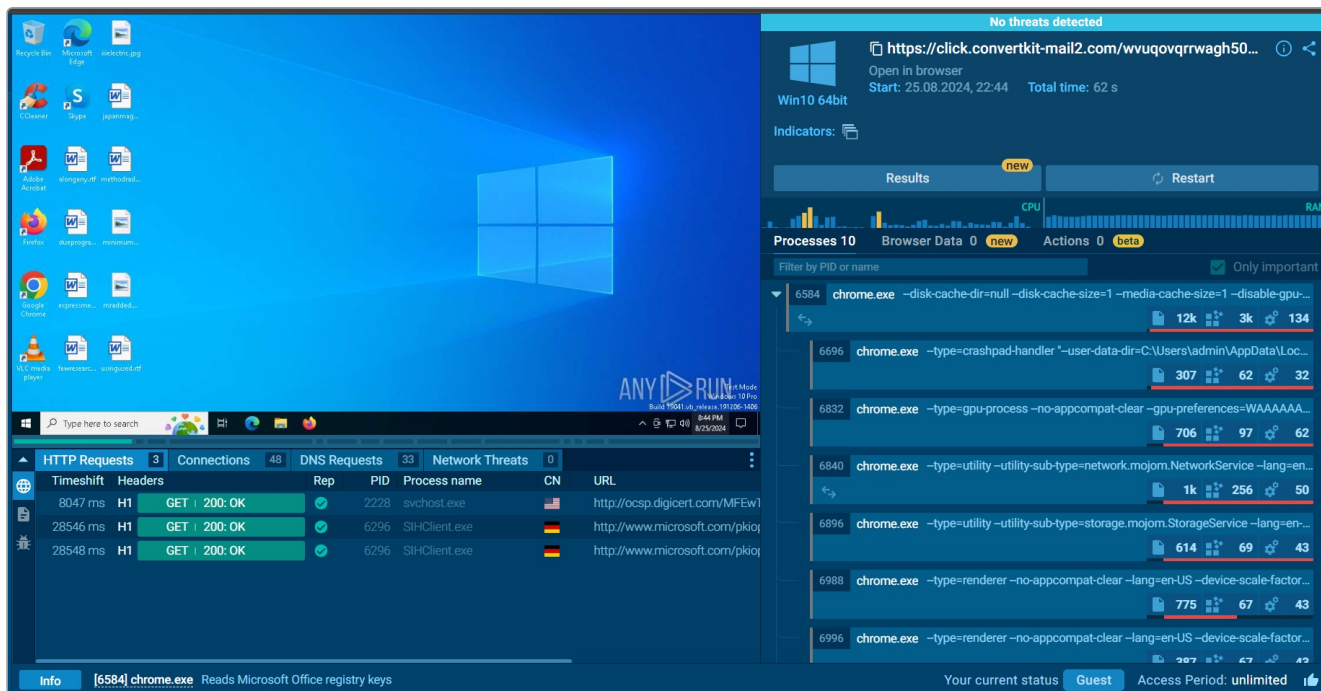


Fig. 1 — Verdetto della sandbox ANY.RUN: "No threats detected". La pagina finale raggiunta è la pagina di login autentica di Facebook.

5. Analisi della URL e della catena di redirect

Il link è composto da tre parti: un identificativo dell'iscritto alla newsletter, un identificativo della campagna email, e un ultimo segmento codificato in **Base64** (una comune codifica testuale, non una cifratura), che è stato decodificato manualmente ottenendo:

`www.instagram.com/aussienurserecruiters`

Questo conferma, in modo indipendente dal comportamento osservato nel browser, che la destinazione finale dichiarata nel link corrisponde esattamente a quella realmente raggiunta durante l'esecuzione in sandbox. Negli screenshot seguenti si osserva la catena di redirect completa: dal link ConvertKit alla pagina di login Instagram (Fig. 2) e, in un secondo scenario di test, alla pagina di login Facebook (Fig. 3).

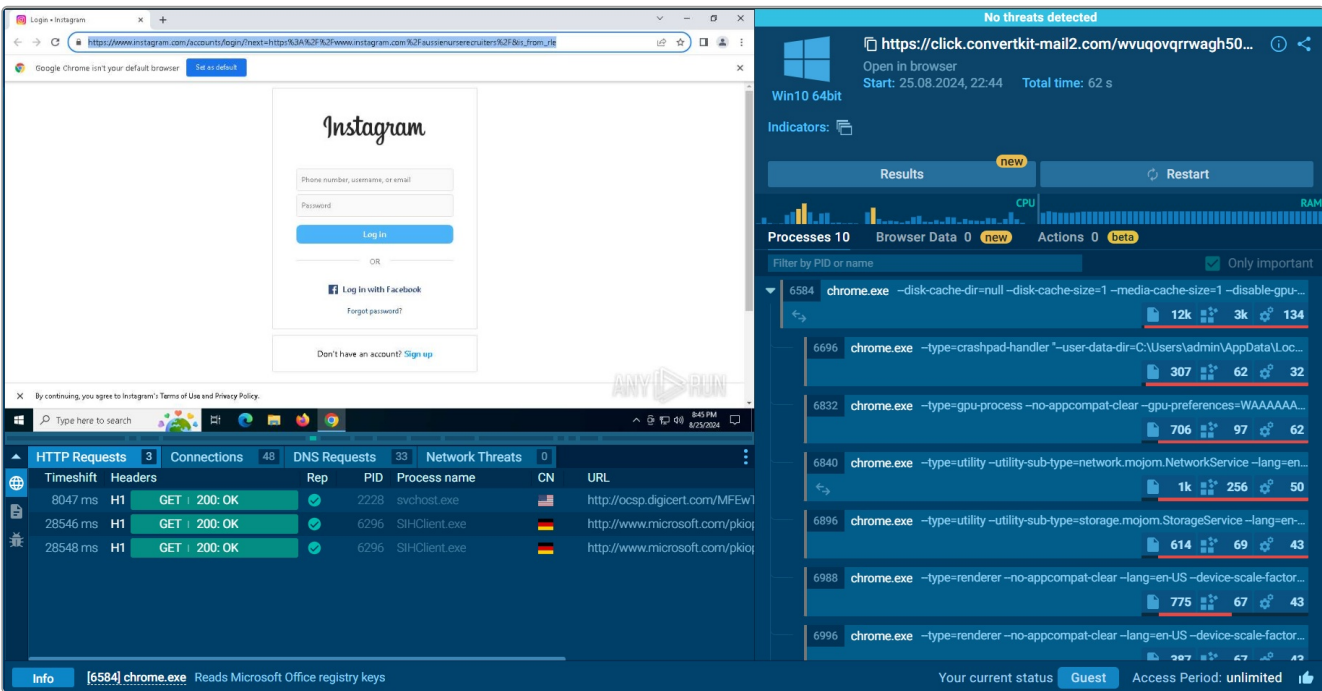


Fig. 2 — Il browser raggiunge la pagina di login autentica `instagram.com`, con URL in chiaro nella barra degli indirizzi.

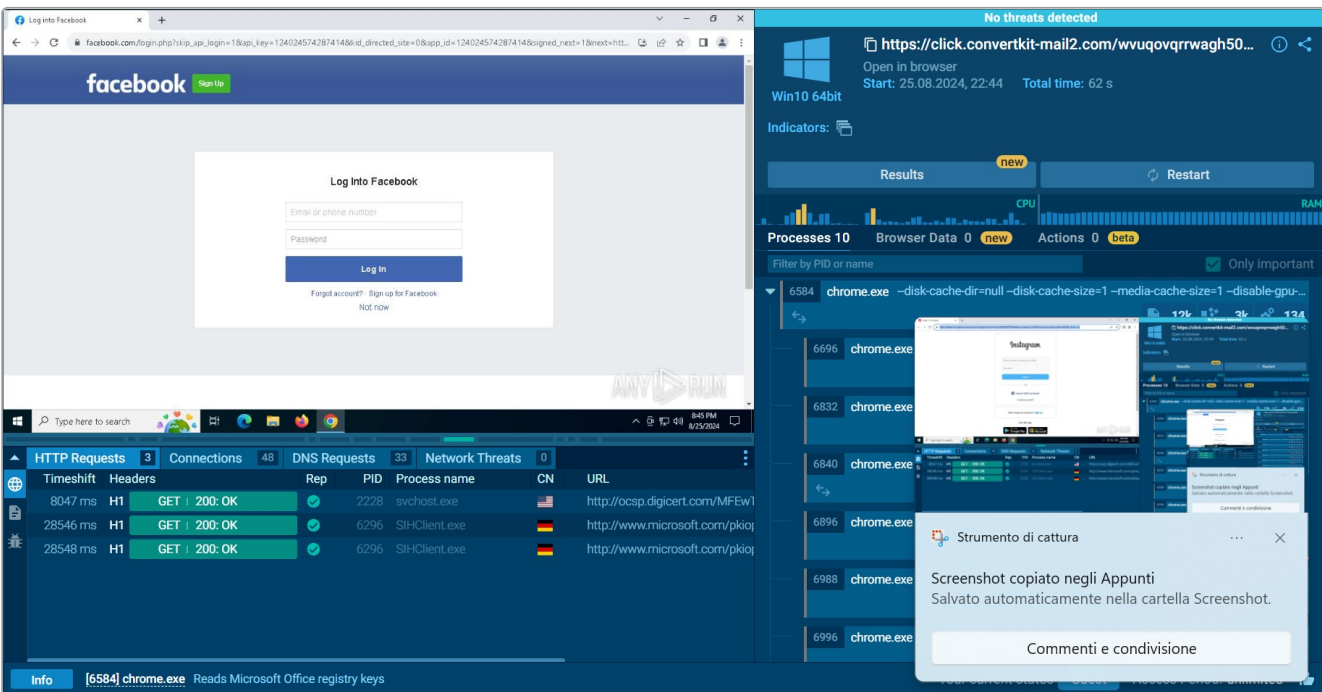


Fig. 3 — Il browser raggiunge la pagina di login autentica `facebook.com/login.php` con parametri OAuth standard (`api_key`, `app_id`).

In entrambi i casi non sono stati rilevati domini contraffatti (typosquatting), certificati anomali, né moduli di inserimento

credenziali che inviassero dati verso server terzi non riconducibili a Meta.

6. Analisi del traffico di rete e DNS

Tutte le connessioni di rete generate durante l'esecuzione sono state verificate incrociando processo generante, IP di destinazione, provider (ASN) e corrispondenza con la risoluzione DNS del dominio.

Categoria traffico	Processo	Destinazione	Valutazione
Navigazione verso il sito target	chrome.exe	convertkit-mail2.com → instagram.com / facebook.com / fbcdn.net / cdninstagram.com	VERO NEGATIVO
Servizi integrati nel browser	chrome.exe	accounts.google.com, content-autofill.googleapis.com	VERO NEGATIVO
Validazione certificati SSL (OCSP/CRL)	svchost.exe, SIHClient.exe	ocsp.digicert.com, microsoft.com/pkiops	VERO NEGATIVO
Telemetria e Windows Update	svchost.exe, MoUsoCoreWorker.exe, SIHClient.exe	settings-win.data.microsoft.com, login.live.com, slscr.update.microsoft.com	VERO NEGATIVO
Discovery di rete locale	chrome.exe, svchost.exe	Multicast SSDP/mDNS (239.255.255.250, 224.0.0.251)	VERO NEGATIVO
Processo non identificato	RUXIMICS.exe	settings-win.data.microsoft.com (IP legittimo Microsoft)	DA VERIFICARE

Le risoluzioni DNS di tutti i domini sopra elencati sono state confermate coerenti con i blocchi IP ufficiali dei rispettivi provider (Amazon/AWS per ConvertKit, Meta per Facebook/Instagram, Google, Microsoft, Akamai/Edgecast per le CDN). Non è stato rilevato alcun pattern di generazione automatica di domini (DGA) né alcuna risoluzione verso indirizzi anomali o non pertinenti al nome del dominio richiesto.

7. Analisi dei processi

È stato analizzato l'albero completo dei processi generati durante l'esecuzione (10 processi totali), inclusa la command line con cui ciascuno è stato lanciato. Il processo padre `chrome.exe` è stato avviato esattamente con l'URL fornito, senza alcuna manipolazione. Tutti i processi figli (`--type=gpu-process`, `--type=utility`, `--type=renderer`, `--type=crashpad-handle`) corrispondono all'architettura multiprocesso standard del browser Chromium, utilizzata per isolare per sicurezza ogni scheda, la grafica e la rete in processi separati.

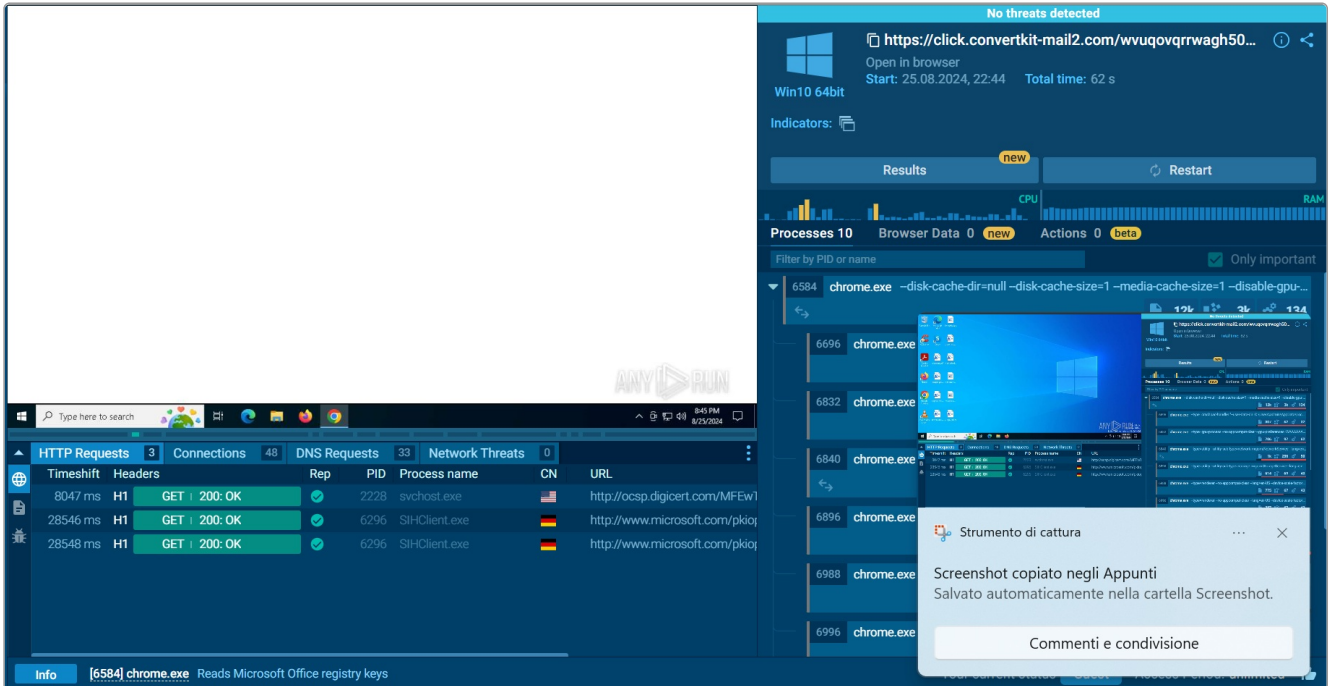


Fig. 4 — Albero dei 10 processi Chrome generati durante l'analisi, tutti coerenti con il normale funzionamento del browser.

Non è stato riscontrato alcun processo estraneo (script PowerShell, eseguibili in cartelle temporanee, strumenti di sistema invocati in modo anomalo). L'unico indicatore comportamentale segnalato dalla sandbox è **"Reads Microsoft Office registry keys"** sul processo principale di Chrome: si tratta di un evento isolato e a bassa severità, tipico controllo di sistema sugli handler dei file predefiniti, non correlato a tecniche di attacco note (es. sfruttamento di macro Office o furto di credenziali).

8. Elemento di attenzione: processo RUXIMICS.exe

Elemento non collegato al link analizzato — approfondito separatamente

Nel log delle connessioni di rete registrate nella fase precedente all'esecuzione del link ("BEFORE"), è stato individuato un processo denominato `RUXIMICS.exe` che comunica con l'endpoint Microsoft `settings-win.data.microsoft.com`.

Motivi per cui, inizialmente, questo elemento ha richiesto un approfondimento dedicato, distinto dal link analizzato:

- Il nome del processo non corrispondeva a nessun componente osservato nel resto dell'analisi (Chrome, ecosistema Meta/Google).
- La destinazione contattata era un dominio Microsoft legittimo, ma questo da solo non è una garanzia sufficiente.
- Il processo era già attivo **prima** dell'esecuzione del link in analisi: questo esclude fin da subito un collegamento diretto con la campagna email ConvertKit.

Esito della verifica bibliografica

È stata condotta una ricerca su fonti tecniche indipendenti (documentazione Microsoft Q&A, database di processi Windows, forum di supporto specializzati) per identificare la natura di questo eseguibile. Le fonti risultano concordi nell'indicare quanto segue:

- `RUXIMICS.exe` corrisponde a **"Reusable UX Interaction Manager"**, componente ufficiale del servizio Windows

Update, utilizzato da Microsoft per pianificare e distribuire notifiche e aggiornamenti (incluse le proposte di upgrade a Windows 11).

- Il percorso di installazione legittimo atteso è `C:\Program Files\RUXIM\RUXIMICS.exe`, con firma digitale "Microsoft Corporation".
- Trattandosi di un componente aggiornato periodicamente da Microsoft, il suo hash cambia da una build di Windows Update all'altra: non esiste quindi un singolo hash di riferimento universale, e il confronto con un elenco di hash noti non costituisce, da solo, una prova conclusiva né di legittimità né di compromissione.

Non è stato possibile, con i dati attualmente disponibili, recuperare il percorso di installazione, la firma digitale o l'hash del campione specifico osservato in questa sessione: questi sarebbero gli elementi che, se disponibili, permetterebbero una conferma definitiva al 100%.

Chiusura del punto

In assenza di ulteriori elementi disponibili, e considerato che: (a) il processo è coerente per nome e comportamento di rete con un componente Microsoft noto e documentato; (b) la destinazione di rete contattata è ufficiale Microsoft; (c) non è stato osservato alcun comportamento aggiuntivo di rete o di file anomalo riconducibile a questo processo, il punto viene **chiuso come presumibilmente legittimo**, senza azioni di contenimento (nessuna quarantena, nessuna eliminazione, nessuna blacklist). Si tratta di una chiusura basata sul miglior livello di confidenza raggiungibile con i dati disponibili, non su una verifica crittografica puntuale del campione — per una certezza assoluta servirebbero percorso, firma digitale e hash reali del file, non reperibili al momento.

9. Tabella di classificazione e remediation

Elemento analizzato	Classificazione	Azione raccomandata	Motivazione sintetica
Link ConvertKit → Instagram/Facebook	Vero Negativo Falso Positivo dell'allarme iniziale	Chiudere il ticket come falso positivo; whitelist se bloccato da filtri email	Confermato legittimo su 5 livelli di verifica indipendenti e concordanti
Pagine di login facebook.com / instagram.com	Vero Negativo	Nessuna azione	Domini ufficiali Meta, nessuna contraffazione
Dominio convertkit-mail2.com	Vero Negativo	Non inserire in blacklist	Infrastruttura legittima di email marketing (ConvertKit/Kit su AWS)
Traffico verso Microsoft/DigiCert (OCSP, CRL, Update)	Vero Negativo	Nessuna azione / whitelist permanente se non presente	Processi di sistema Windows nativi, traffico di manutenzione standard
Albero processi Chrome (10 processi)	Vero Negativo	Nessuna azione	Architettura multiprocesso standard di Chromium, nessuno script o binario estraneo
Indicatore "Reads Microsoft Office registry keys"	Falso Positivo	Nessuna azione	Evento isolato a bassa severità, non correlato a tecniche di attacco note
Processo RUXIMICS.exe	Presumibile Falso Positivo (confidenza alta, non verifica crittografica puntuale)	Nessuna azione di contenimento; chiuso sulla base di verifica bibliografica indipendente	Identificato come "Reusable UX Interaction Manager", componente Windows Update legittimo; non collegato al link; percorso/firma/hash del campione reale non disponibili per conferma al 100%
Campagna email di origine (profilo "aussienurserecruiters")	N/A	Verifica interna con reparto marketing/HR	Confermare che sia una collaborazione/campagna autorizzata dall'azienda

10. Conclusioni finali

Sintesi per il management

Il link segnalato non rappresenta una minaccia. È un normale strumento di tracciamento click di una piattaforma di email marketing legittima, che reindirizza correttamente alle pagine di accesso autentiche di Instagram e Facebook. La conclusione è supportata da cinque metodi di verifica tecnica indipendenti, tutti concordanti, il che rende il caso solido e chiudibile senza ambiguità.

Durante l'approfondimento è emerso un elemento distinto e non collegato al link (il processo `RUXIMICS.exe`). La verifica bibliografica condotta lo identifica come componente legittimo di Windows Update. Il punto viene chiuso come presumibile falso positivo con alta confidenza, pur restando una conferma crittografica puntuale del campione (percorso, firma digitale, hash) non effettuabile con i dati attualmente disponibili — un approfondimento facoltativo per una certezza assoluta, ma non bloccante per la chiusura del presente caso.

Report generato dal Team Akatsuki sulla base dei dati forniti dalla piattaforma di sandboxing ANY.RUN. Le evidenze fotografiche e i log inclusi in questo documento sono stati raccolti durante l'esecuzione controllata del 25.08.2024. Documento ad uso interno del cliente.